

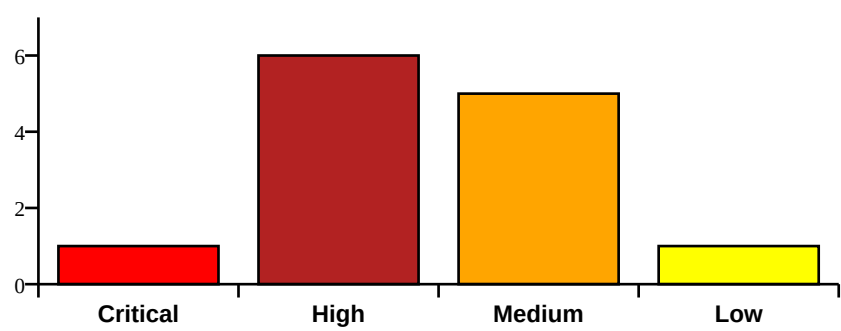
Vulnerability Scan Report

Target URL: http://testphp.vulnweb.com/login.php
Generated (UTC): 2025-12-25 10:32:43Z

Summary

Metric	Count
Total Vulnerabilities	13
Critical Severity	1
High Severity	6
Medium Severity	5
Low Severity	1

Severity Distribution



Detected Vulnerabilities

Type	Location	Evidence / Payload	Severity
XSS	http://testphp.vulnweb.com/login.php	'-alert(1)//	Medium
XSS	http://testphp.vulnweb.com/login.php	alert(1);	Medium
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
NoSQL Injection	http://testphp.vulnweb.com/login.php	{"\$ne": null}	High
Command Injection	http://testphp.vulnweb.com/login.php	;& ls	Critical
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Application does not enforce HTTPS	High
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Strict-Transport-Security header not set	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Multiple rapid requests allowed without restriction	High

Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Sensitive endpoint accessible without auth: /admin	High
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: No CAPTCHA or bot protection detected	Low
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: PUT method is enabled	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: DELETE method is enabled	Medium

Activity Log

```
[10:31:48] [+] Loaded 6606 payloads for XSS
[10:31:48] [+] Loaded 4 payloads for SQL Injection
[10:31:48] [+] Loaded 3 payloads for NoSQL Injection
[10:31:48] [+] Loaded 4 payloads for Command Injection
[10:31:48] [+] Found: http://testphp.vulnweb.com/login.php
[10:31:49]
=====
[10:31:49] Starting Vulnerability Scan for http://testphp.vulnweb.com/login.php
[10:31:49]
=====
[10:31:49]
===== Testing for XSS =====
[10:31:49]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:31:58] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[10:31:58] payload: &#x27;-alert(1)//
[10:31:58] Severity: Medium
[10:31:58] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot;>
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot;>
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot;/></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot;/></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot;><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot;/></td></tr>
</table>
</form>

[10:31:58]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:31:59] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[10:31:59] payload: <script>alert(1);</script>
[10:31:59] Severity: Medium
[10:31:59] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;>
<label>search art</label>
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot;/>
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot;/>
</form>

[10:31:59]
===== Testing for SQL Injection =====
[10:31:59]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:31:59] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[10:31:59] payload: OR &#x27;1&#x27;=&#x27;1 --
[10:31:59] Severity: High
[10:31:59] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot;>
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot;>
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot;/></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot;/></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot;><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot;/></td></tr>
</table>
</form>

[10:31:59]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:32:00] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[10:32:00] payload: OR &#x27;1&#x27;=&#x27;1 --
[10:32:00] Severity: High
[10:32:00] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;>
<label>search art</label>
```

```
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot; />
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot; />
</form>
```

[10:32:00]

===== Testing for NoSQL Injection =====

[10:32:00]

[+] Testing form in http://testphp.vulnweb.com/login.php

[10:32:02]

[+] Testing form in http://testphp.vulnweb.com/login.php

[10:32:02] [***] Possible NoSQL Injection in form at: http://testphp.vulnweb.com/login.php

[10:32:02] payload: {"\$ne";: null}

[10:32:02] Severity: High

[10:32:02] form: <form action="search.php?test=query" method="post">

<label>search art</label>

<input name="searchFor" size="10" type="text" />

<input name="goButton" type="submit" value="go" />

</form>

[10:32:02]

===== Testing for Command Injection =====

[10:32:02]

[+] Testing form in http://testphp.vulnweb.com/login.php

[10:32:05]

[+] Testing form in http://testphp.vulnweb.com/login.php

[10:32:06] [***] Possible Command Injection in form at: http://testphp.vulnweb.com/login.php

[10:32:06] payload: ;& ls

[10:32:06] Severity: Critical

[10:32:06] form: <form action="search.php?test=query" method="post">

<label>search art</label>

<input name="searchFor" size="10" type="text" />

<input name="goButton" type="submit" value="go" />

</form>

[10:32:06]

===== Testing for Cryptographic Failures =====

[10:32:06]

===== SCANNING http://testphp.vulnweb.com/login.php =====

[10:32:06] [INFO] Checking scheme → http

[10:32:06] [INFO] Initiating TLS handshake

[10:32:11] [SKIP] TLS check skipped → timed out

[10:32:11] [INFO] Checking cipher suite

[10:32:16] [SKIP] Cipher check skipped → timed out

[10:32:16] [INFO] Retrieving TLS certificate

[10:32:21] [SKIP] Certificate check skipped → timed out

[10:32:21] [HTTP] Checking HSTS header

[10:32:21] [HTTP] Response status → 200

[10:32:21] [HTTP] Response headers → {'Server'; 'nginx/1.19.0';, 'Date';
'Thu, 25 Dec 2025 10:33:44 GMT';, 'Content-Type'; 'text/html; charset=UTF-8';,
'Transfer-Encoding'; 'chunked';, 'Connection'; 'keep-alive';,
'X-Powered-By'; 'PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1';, 'Content-
Encoding'; 'gzip';}

[10:32:21] [SCAN] Checking for weak hashes and sensitive data

[10:32:22]

===== REPORT =====

[10:32:22] - [High] HTTPS not enforced

[10:32:22] - [Medium] HSTS header missing

[10:32:22]

===== SCORE =====

[10:32:22] Crypto Risk Score → 50/100

[10:32:22] Risk Level → MEDIUM

[10:32:22]

===== Insecure Design Scan =====

[10:32:22]

[+] Checking rate limiting...

[10:32:22] [LOG] GET /login.php → 200 (len=5523, 0.56s)

[10:32:23] [LOG] GET /login.php → 200 (len=5523, 0.56s)

[10:32:24] [LOG] GET /login.php → 200 (len=5523, 0.57s)

[10:32:25] [LOG] GET /login.php → 200 (len=5523, 0.54s)

[10:32:25] [LOG] GET /login.php → 200 (len=5523, 0.54s)

[10:32:26] [LOG] GET /login.php → 200 (len=5523, 0.54s)

[10:32:27] [LOG] GET /login.php → 200 (len=5523, 0.55s)

[10:32:28] [LOG] GET /login.php → 200 (len=5523, 0.54s)

[10:32:28]

[+] Checking authorization design...

[10:32:29] [LOG] GET /admin → 200 (len=262, 0.80s)

[10:32:29] [LOG] GET /admin/login → 404 (len=153, 0.54s)

[10:32:30] [LOG] GET /administrator → 404 (len=153, 0.56s)

[10:32:31] [LOG] GET /manage → 404 (len=153, 0.55s)

[10:32:31] [LOG] GET /user → 404 (len=153, 0.54s)

[10:32:32] [LOG] GET /account → 404 (len=153, 0.53s)
[10:32:32] [LOG] GET /profile → 404 (len=153, 0.53s)
[10:32:33] [LOG] GET /login → 404 (len=153, 0.54s)
[10:32:33] [LOG] GET /register → 404 (len=153, 0.54s)
[10:32:34] [LOG] GET /auth → 404 (len=153, 0.54s)
[10:32:34] [LOG] GET /api → 404 (len=153, 0.55s)
[10:32:35] [LOG] GET /api/admin → 404 (len=153, 0.54s)
[10:32:36] [LOG] GET /api/private → 404 (len=153, 0.60s)
[10:32:36] [LOG] GET /checkout → 404 (len=153, 0.56s)
[10:32:37] [LOG] GET /payment → 404 (len=153, 0.58s)
[10:32:37] [LOG] GET /orders → 404 (len=153, 0.53s)
[10:32:39] [LOG] GET /upload → 404 (len=153, 1.37s)
[10:32:39] [LOG] GET /debug → 404 (len=153, 0.55s)
[10:32:40] [LOG] GET /test → 404 (len=153, 0.56s)
[10:32:40] [LOG] GET /dev → 404 (len=153, 0.55s)
[10:32:40]
[+] Checking business logic trust...
[10:32:41] [LOG] POST /login.php → 200 (len=5523, 0.54s)
[10:32:41] ✓ Business logic validation detected
[10:32:41]
[+] Checking abuse protection (CAPTCHA)...
[10:32:41] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[10:32:41]
[+] Checking HTTP method exposure...
[10:32:42] [LOG] PUT /login.php → 200 (len=5523, 0.54s)
[10:32:42] [LOG] DELETE /login.php → 200 (len=5523, 0.55s)
[10:32:43] [LOG] TRACE /login.php → 405 (len=157, 0.54s)